MODULE 15 · DOMAIN 3 - INTEGRATION

Identity, Authorisation and Security Gaps

Whose authority the agent acts with, where access is checked, where secrets live, what gets recorded, and how untrusted content attacks the design.

DOMAIN 3 of 7 EXAM WEIGHT 19% MODULE 15 of 38

admin@sthithapragna.com

Claude acts with someone's authority.
Know whose, limit it, and record it.

Four questions for any integration

QUESTION	WHAT A GOOD ANSWER LOOKS LIKE
Who is acting?	The signed-in user, or a named service identity
What may they do?	Scopes checked in code, on every call
Where do secrets live?	A secret store, injected at call time, short-lived
What is recorded?	User, agent, tool, arguments, outcome, correlation ID

ON THE EXAM

Authentication proves who someone is. Authorisation decides what they may do. Gaps hide in the second.

One shared key, or the user's own identity?

SHARED SERVICE KEY

Everyone is the agent

- Every call looks the same
- Rights are the union of all users
- One leak exposes every customer
- Logs cannot say who acted

DELEGATED, PER USER

The user, through the agent

- Calls carry the user's identity
- The agent can do no more than the user
- Revoke one user, not everyone
- Every action is attributable

THE TIEBREAKER

Use a service identity only for work no user owns, such as a nightly batch, and scope it to that job.

Authorise before retrieval

- **Filtering at display is too late.** The model has already read the passage.
- **Filter in the retrieval query** by the user's entitlements, or keep separate indexes.
- **Same rule for tools:** the service checks the user's rights before returning data.
- **A prompt rule is not a filter.** Anything in context can surface in an answer.

> THE PICTURE
>
> Reading a confidential letter aloud, then asking the room to forget it.

Where credentials must never live

NEVER HERE	BECAUSE
System prompt or any context	The model can repeat it, and context is logged
Repos and shared config files	Committed once, copied forever
Logs, traces and transcripts	Read by far more people than the key should be
Tool arguments the model writes	The model should never handle the secret at all

ON THE EXAM

Secrets live in a secret store. Your code attaches them at call time. The model never sees them.

Actor attribution

- **Log the human:** which user, in which customer account.
- **Log the agent:** which agent, model version and configuration.
- **Log the act:** tool, arguments, result, approval if any.
- **Join it up:** one correlation ID across every hop.
- **Written by your code,** not by the model.

> ON THE EXAM
>
> 'The agent did it' is never an answer an auditor will accept.

Indirect prompt injection: the exfiltration path

Private data

Customer records
Internal documents

Untrusted content

Emails, web pages, files
Third-party tool results

The agent

Cannot always tell data from orders
Acts with its own access

Reads instructions wherever they appear

A way out

Outbound email or web calls
Links, tickets, uploads

Break one leg

Remove or scope a capability
Or gate it with a human

THE TAKEAWAY

All three together is the danger. Never let one agent hold all three unguarded.

Anthropic's injection mitigations, October 2026

MITIGATION	WHAT IT MEANS
Untrusted content only in tool results	Never in the system prompt or plain user text
Label the source	Say what the content is and where it came from
State the policy	Tool content is data; it never overrides instructions
Encode it	Wrap third-party strings in JSON
Least privilege	A successful injection can do little
Screen, then red-team	A small model checks tool output; test with attacks

ON THE EXAM

Layer them. Anthropic says no system is completely immune, so design for the injection that gets through.

Reviewing a spec for security gaps

01
Map identities
Who acts, on whose behalf?

02
Trace access
Where is each permission checked?

03
Find secrets
Prompt, repo, logs, arguments?

04
Check records
Can every action be attributed?

05
Walk the path
Data, untrusted input, a way out?

ON THE EXAM

Run the same five checks on every design the exam shows you. One of them usually fails.

> Tallyhawk's support agent calls internal APIs with one service key for all 3,200 customer companies. Tool-call logs do not record which customer or user triggered an action.
>
> Enterprise customers' contracts require an audit trail of every action taken on their accounts.

What should Corvane recommend?

A Have the agent write the customer's name into each log entry it creates

B Keep the shared key, and rotate it every week

C Call internal APIs with a credential bound to the signed-in user, and log user, customer and agent on every call

D Have the agent confirm the customer's identity in conversation before acting

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Have the agent write the customer's name into each log entry it creates

Model-written records are claims, not evidence.

B Keep the shared key, and rotate it every week

Fresher key, same gap. Every customer still looks the same.

C Call internal APIs with a credential bound to the signed-in user, and log user, customer and agent on every call

Scoped to the user, attributed by code, auditable per account.

D Have the agent confirm the customer's identity in conversation before acting

Conversation is not authentication.

THE SIGNAL

One key for everyone, no actor in the logs: delegate the user's identity and log it in code.

> Mereside's staff policy assistant retrieves from all 1,800 documents, including HR-restricted ones. Restricted passages are hidden only when the answer is displayed.
>
> An adviser's answer about leave contained a paraphrase of a restricted disciplinary procedure.

What should Corvane recommend?

A. Add a system prompt rule never to use HR-restricted documents

B. Add an output check that removes HR content from answers

C. Rank HR-restricted documents lower in retrieval

D. Filter retrieval by each user's entitlements, so restricted documents never reach the model

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Add a system prompt rule never to use HR-restricted documents

The passage is still in context. Rules are not filters.

B Add an output check that removes HR content from answers

Display filtering again. Paraphrases slip through.

C Rank HR-restricted documents lower in retrieval

Lower is not absent.

D Filter retrieval by each user's entitlements, so restricted documents never reach the model

Access checked before the model reads anything.

THE SIGNAL

Restricted content leaking through answers: authorise at retrieval, not at display.

> A Quillon developer put the billing system's API key in the portal assistant's system prompt, so Claude can include it in the arguments of its billing tool.
>
> The prompt also tells Claude never to reveal the key to patients.

What should Corvane recommend?

A. Remove the key from the prompt; the tool code attaches a credential from the secret store at call time

B. Keep the key, and strengthen the instruction never to reveal it

C. Encrypt the key in the prompt, and let the tool decrypt it

D. Keep the key in the prompt, and rotate it every month

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Remove the key from the prompt; the tool code attaches a credential from the secret store at call time

The model never sees the secret, so it can never leak it.

B Keep the key, and strengthen the instruction never to reveal it

Instructions can be talked round. The key is still in context.

C Encrypt the key in the prompt, and let the tool decrypt it

The ciphertext becomes the key. Same exposure.

D Keep the key in the prompt, and rotate it every month

Shortens exposure; keeps the flaw.

THE SIGNAL

A credential in model context: take it out, and attach it in code at call time.

> Tallyhawk's support agent reads inbound customer emails, can look up any customer account, and can send email to any address.
>
> In a red-team test, an email told the agent to send another customer's invoices to an outside address. It did.

Which design change most directly closes this path?

A Add a system prompt rule to ignore instructions found in emails

B Scope lookups to the sender's own account, and allow replies only to its verified address

C Move the agent to the most capable model tier

D Log every outgoing email for weekly review

◆ PAUSE AND DECIDE

Which design change most directly closes this path?

A Add a system prompt rule to ignore instructions found in emails

Worth adding, but injections are written to get past it.

B Scope lookups to the sender's own account, and allow replies only to its verified address

Breaks two legs: other customers' data, and the way out.

C Move the agent to the most capable model tier

Resists more attacks; the path stays open.

D Log every outgoing email for weekly review

Finds the leak a week after it happened.

THE SIGNAL

Private data, untrusted input and a way out in one agent: break a leg in the design.

> Mereside's mortgage document extraction runs overnight in batches, with no user signed in. It reads new document packs and writes extracted fields for underwriters.
>
> The design draft says it will run under the same administrator service account as Mereside's other scheduled jobs.

What should Corvane recommend?

A Run it under the head of underwriting's personal account

B Keep the shared administrator account, but log more detail

C Give the job its own service identity, scoped to read packs and write extraction results

D Use the token of whichever underwriter signed in most recently

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Run it under the head of underwriting's personal account

A person's rights, used when that person is not acting.

B Keep the shared administrator account, but log more detail

Far too much access, shared with unrelated jobs.

C Give the job its own service identity, scoped to read packs and write extraction results

No user owns the work: a dedicated, narrow identity.

D Use the token of whichever underwriter signed in most recently

Borrowed identity. Wrong actor in every record.

THE SIGNAL

Work no user owns: a dedicated service identity, scoped to that job and nothing else.

> Quillon's prior-authorisation agent reads insurer portal pages and PDF criteria documents, then drafts letters for clinicians to approve.
>
> A red-team PDF contained hidden text telling the agent to paste the full patient record into the letter. The draft did so.

Which two changes follow Anthropic's guidance most directly? Choose two.

A. Return portal and PDF content only in tool results, marked as data, not instructions

B. Screen each tool result with a small classifier model before Claude sees it

C. Paste the PDF text into the user message, so Claude reads it carefully

D. Rely on the most capable model tier to recognise attacks

E. Ask Claude at the end of each letter whether it followed any hidden instructions

◆ PAUSE AND DECIDE

Which two changes follow Anthropic's guidance most directly? Choose two.

A Return portal and PDF content only in tool results, marked as data, not instructions

Where Claude treats instructions with scepticism.

B Screen each tool result with a small classifier model before Claude sees it

Catches attacks before Claude reads them.

C Paste the PDF text into the user message, so Claude reads it carefully

The opposite: untrusted text gains the user's voice.

D Rely on the most capable model tier to recognise attacks

Helps, but no model is immune. It is not a design.

E Ask Claude at the end of each letter whether it followed any hidden instructions

Self-report from the system under attack.

THE SIGNAL

Untrusted documents: in tool results, labelled as data, screened first.

In five lines

- **Act as the user,** not as a shared key. Service identities only for unowned work, narrowly scoped.
- **Authorise before retrieval.** Display filters and prompt rules are not access control.
- **Secrets never in context, repos or logs.** Code attaches them at call time.
- **Log the actor in code:** user, agent, tool, outcome, correlation ID.
- **Private data, untrusted input, a way out:** never all three unguarded.

> COMING UP
>
> Next: accuracy-latency trade-offs and observability at scale.